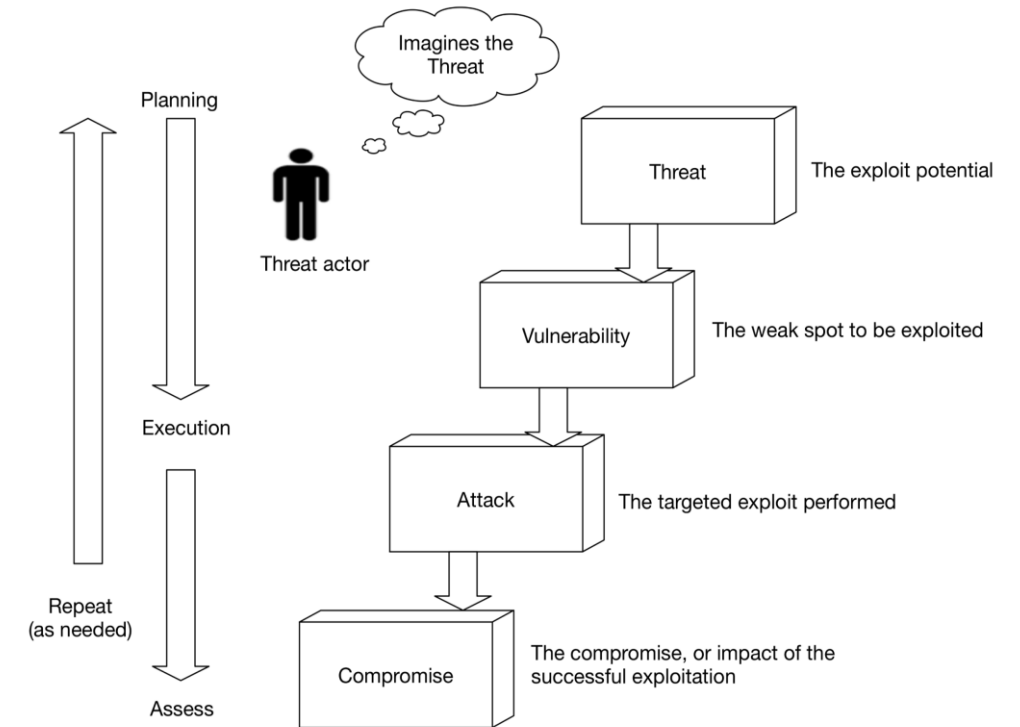


- **Confidentiality:** Keeping sensitive information secret and protected from disclosure
- **Integrity:** Ensuring that information is not modified, accidentally or purposefully, without being detected
- **Availability:** Ensuring that information and capabilities are available when needed
- **Authentication:** Ensuring that the source of data is from a known identity or endpoint (generally follows identification)
- **Non-repudiation:** Ensuring that an individual or system cannot later deny having performed an action

- Resilience: maintaining state awareness and an accepted level of operational normalcy in response to disturbances, including threats of an unexpected and malicious nature.
- Safety: not being in threat of undergoing or causing hurt, injury, or loss.

Common Attacks Against the IoT

- Wired and wireless scanning and mapping attacks
- Protocol attacks
- Eavesdropping attacks (loss of confidentiality)
- Cryptographic algorithm and key management attacks
- Spoofing and masquerading (authentication attacks)
- Operating system and application integrity attacks
- Denial of service and jamming
- Physical security attacks (for example, tampering and interface exposures)
- Access control attacks (privilege escalation)



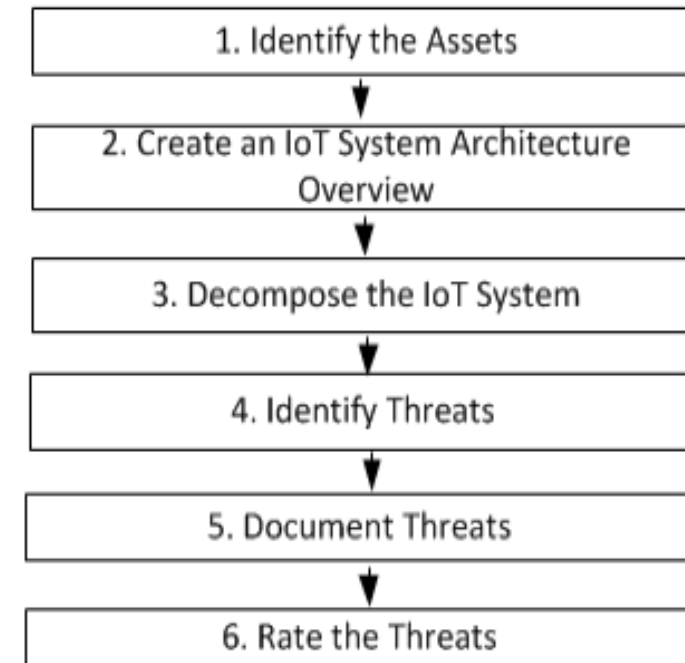
Russel & Van Duren: "Practical Internet of Things Security", 2nd edition, Packt Publishing, 2019

- Capabilities of the attacker, such as technical ability, notice ability, and cost of the attack
- Behaviours and probabilities of the attack such as how the attack would be conducted and the likelihood of success
- Impact of the attack to the victim (note that low impacts for individual aspects of an attack may aggregate to a final impact that can be enormous)
- Benefits to the attacker (of given impacts) are motivating impacts for the attack
- Detriments to the attacker are demotivators for the attack

- Authentication attacks
 - “The Mirai Botnet in late 2016 was formed by exploiting IP cameras and internet router equipment default passwords.”
- Distributed Denial of Service (DDoS)
 - “While Mirai's authentication attack vector was relatively simple, its effect scaled to a Botnet consisting of millions of devices that were used to launch attacks against the internet's DNS system.”
- Application security attacks
 - “IoT devices and connections can be exploited through attacks against application endpoints. ... Application code running on the device itself can also be directly targeted.”

- Wireless reconnaissance and mapping
 - “[The] Texas-based company Praetorian, which in Austin, TX, has used a low-flying drone outfitted with a custom ZigBee protocol scanner to identify thousands of ZigBee-enabled IoT device beacon requests. Just as network scanning using tools such as Nmap are commonly utilized by hackers to gather intelligence about network hosts, subnets, ports, and protocols, similar paradigms are being used against IoT devices—things that may open your garage door, lock your front door, turn lights on and off, and so on.”
- Security protocol attacks
 - “[R]esearchers found while testing a ZigBee-based consumer IoT implementation that the protocol was designed for easy setup and usage but lacked configuration possibilities for security and performed vulnerable device pairing procedures. These procedures allow external parties to sniff the exchanged network key during the ZigBee pairing transaction and gain control of the ZigBee device. ... [The] WPA2 (Wi-Fi protected access) cryptographic protocol built into almost every home and business wireless router. In late 2017, this protocol was found, by security researcher, Mathy Vanhoef, to be vulnerable to a class of attack called a key reinstallation attack, wherein the attacker forces the device (in this case, in perfect accordance with the standardized protocol) to reuse a cryptographic key (see <https://www.krackattacks.com/>). ”
- Physical security attacks
 - “Once accessed over an exposed interface (for example, JTAG), the attacker can readily access memory, sensitive key material, passwords, configuration data, and a variety of other sensitive parameters.”

- Identify assets and use cases
 - Components
 - Architecture
 - Application
 - Context
 - Framework
 - Environment
- Identify realistic (and unrealistic) threats
- Rate threats (on perceived probability)

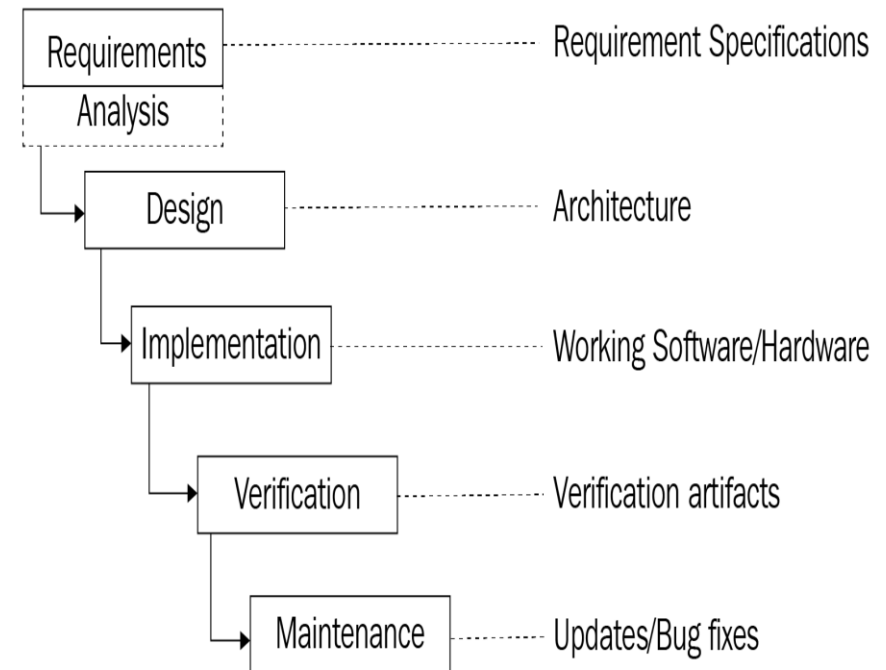


Russel & Van Duren: "Practical Internet of Things Security", 2nd edition, Packt Publishing, 2019

- **Security by design**
- **Lowest common denominator approach**
 - If the security solution fits and works on a sensor or a very small (pico) board, it can fit and work on all other devices and subsystems
 - Effectiveness vs. cost
- **Potential security solutions**
 - Physical Unclonable Functions
 - Trusted Platform Module
 - Security co-processor
 - Cryptographic library
- **Potential platform dependencies**
- **Need for a system approach**

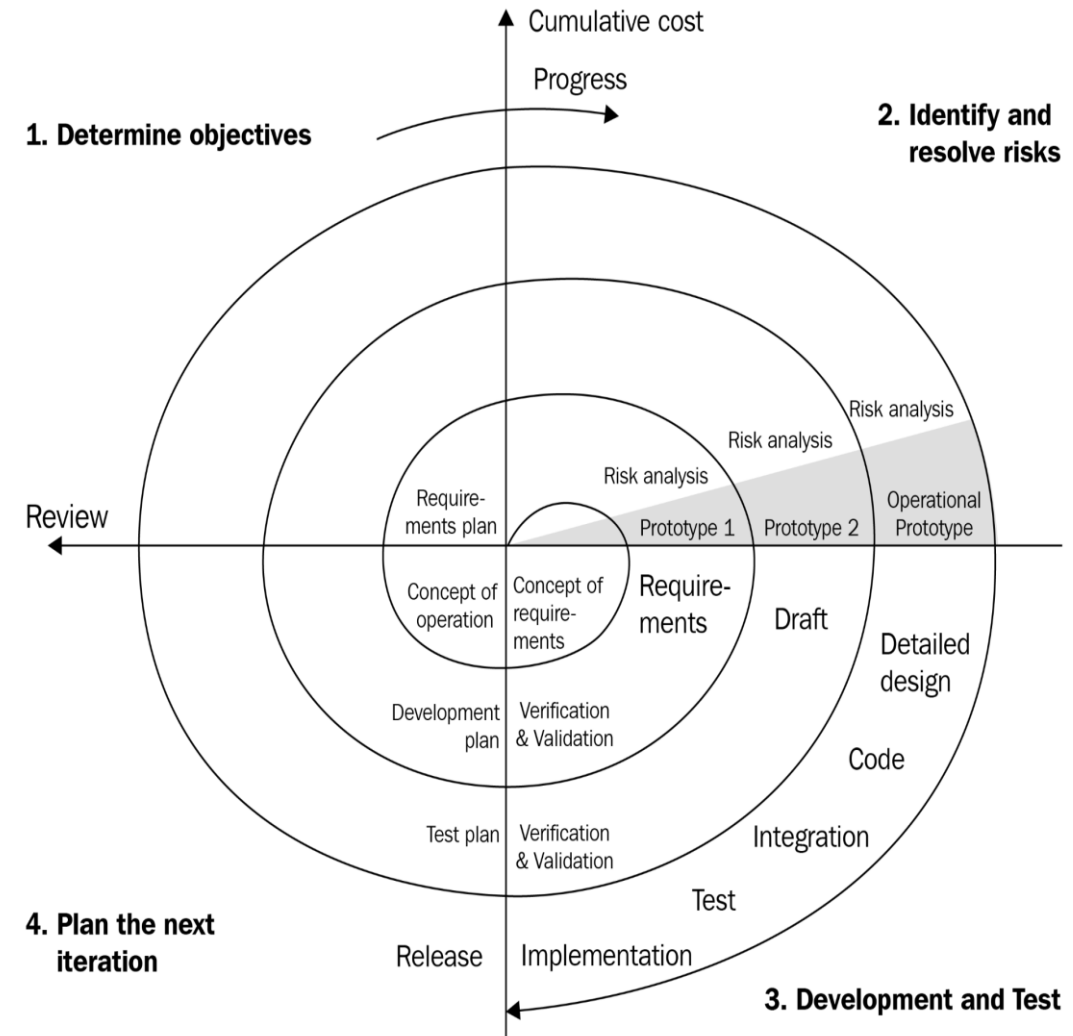
- **Security by Design**
- **Secure Development Life Cycle (SDLC)**
 - The development of security from scratch in the framework of a system is essentially the same as software development from scratch
- **Different Development Models**
 - Waterfall
 - Spiral
 - Agile
 - DevOps
- **Product life cycles impact:**
 - The methodologies we select to develop and manage security requirements
 - Satisfaction of those requirements in the design
 - How we respond to changes (and vulnerabilities) in the marketplace

- **No iterations or feedback**
 - They could potentially be added as well as feedback (Royce's final model, iterative waterfall, waterfall with feedback)



Russel & Van Duren: "Practical Internet of Things Security", 2nd edition, Packt Publishing, 2019

- **Addresses the iteration issue and is based on feedback**
- **However, it is still mostly one-way regarding progress (issues discovered late would require a restart of the development model)**



Russel & Van Duren: "Practical Internet of Things Security", 2nd edition, Packt Publishing, 2019

- **Not based on an exact plan!**
- **Based on principles of agility:**
 - Individuals and interactions over processes and tools (no need to stick to a particular tool or process)
 - Working software over comprehensive documentation (aiming for a working result and not documentation of failure)
 - Customer collaboration over contract negotiation (aiming to meet the customer's needs and not just to provide what the contract may read, which may not be what the customer had in mind – the customer may have limited technical knowledge)
 - Responding to change over following a plan (flexibility, efficiency, not blindly following a plan that may no longer be relevant)
- **Very efficient if progress is supervised and deadlines are met, otherwise extremely chaotic and erratic**